

Security Assessment Report

Store Bloxhouse - Sanitized Portfolio Edition

Target	Bloxhouse / store application
Assessment Type	White Box Testing
Assessment Period	June 19-20, 2026
Prepared by	Muhammad Khadafi
Publication Status	Sanitized for authorized portfolio publication

Executive Summary

A targeted white-box penetration test was conducted against the Store Bloxhouse gaming top-up platform to evaluate invoice generation, payment processing, API security, access control, input validation, and abuse-prevention controls.

The assessment identified three security weaknesses. The most significant was an Insecure Direct Object Reference (IDOR) in invoice verification that allowed unauthorized access to other customers' invoice records and associated personal information. Additional findings involved public exposure of internal API documentation and missing rate-limiting / replay-protection controls in invoice generation.

Several important security controls were also tested and successfully resisted exploitation, including XSS, SQL injection, payment amount manipulation, and payment bypass attempts.

Portfolio note: This edition removes sensitive identifiers and customer information while preserving the assessment approach, vulnerability mechanics, impact, and remediation recommendations.

1. Scope & Authorization

Component	Status
Public Website & API	In Scope
Input Validation	In Scope
Payment Flow Bypass & Manipulation Testing	In Scope
Invoice Creating Flow	In Scope

2. Methodology

The assessment used a white-box approach with relevant information about the application architecture, payment workflow, invoice-generation process, and API structure available to the tester.

- Manual security review of transaction-related functionality
- API request manipulation and parameter tampering
- Authorization and access-control testing
- Business-logic validation across invoice and payment workflows
- Controlled replay / abuse scenarios
- Validation of security controls against common web attack techniques

Testing was performed in a controlled and non-destructive manner. No intentional disruption to business operations was introduced.

3. Findings Summary

ID	Finding	Severity	Status
F-01	IDOR in Invoice Verification	High	Identified
F-02	Public Internal API Documentation Exposure	Medium	Identified
F-03	Missing Rate Limiting / Replay Protection	Medium	Identified

4. Detailed Finding - F-01

Insecure Direct Object Reference (IDOR) in Invoice Verification

Severity: High

Root Issue: The invoice verification function accepted a user-supplied invoice reference without enforcing object-level authorization against the requesting user.

Description

By modifying the invoice reference value in the verification request, an unauthorized user could retrieve invoice information belonging to another customer. The affected response exposed transaction-related information, including personally identifiable information (PII).

Proof of Concept

The original report used concrete invoice identifiers and customer data. For portfolio publication, the identifiers and returned records are intentionally redacted while preserving the exploitation logic.

1. Access the invoice verification functionality.
2. Intercept the request with Burp Suite.
3. Replace the invoice reference with another valid identifier:

```
GET /invoice/
```

4. Submit the modified request and observe that the server returns invoice data belonging to a different customer.

Sanitized result: The response returned another customer's invoice record, including transaction information and PII such as name, phone number, and email address.

Impact

- Unauthorized access to customer invoice records
- Disclosure of personally identifiable information
- Enumeration of valid invoice identifiers
- Loss of confidentiality for transaction data
- Increased risk of targeted attacks against affected customers

Recommendation

- Enforce server-side authorization on every invoice lookup
- Validate that the authenticated requester owns or is authorized to access the referenced invoice
- Apply object-level access control consistently across invoice endpoints
- Prefer non-predictable identifiers where appropriate
- Monitor for abnormal invoice-enumeration behavior

5. Detailed Finding - F-02

Public Exposure of Internal API Documentation

Severity: Medium

Root Issue: The `/docs` endpoint was accessible without authentication and exposed internal API definitions.

Description

The public documentation exposed application structure, endpoint definitions, request and response schemas, parameters, authentication mechanisms, and references to privileged or administrative functionality. No direct unauthorized access to privileged operations was demonstrated through this exposure alone.

Proof of Concept

1. Request the documentation endpoint without authentication:

```
GET /docs
```

2. Observe that API documentation is returned to an unauthenticated user.
3. Review endpoint definitions and references to internal or administrative functionality.

Impact

- Disclosure of internal API architecture
- Increased visibility into privileged functionality
- Reduced reconnaissance effort for attackers
- Expanded awareness of the application attack surface

Recommendation

- Restrict documentation endpoints to authorized users or internal environments
- Disable development/internal API documentation in production where not required
- Review exposed API definitions and remove unnecessary privileged references

6. Detailed Finding - F-03

Missing Rate Limiting and Replay Protection in Invoice Generation

Severity: Medium

Root Issue: Previously submitted invoice-generation requests could be replayed multiple times without sufficient uniqueness or frequency controls.

Proof of Concept

1. Generate a valid invoice.
2. Capture the invoice-generation request using Burp Suite.
3. Replay the same request multiple times.
4. Observe that the application continues to process the requests and create new invoice records.

```
POST /api/invoice/generate-invoice
```

The original assessment observed successful processing of replayed requests. The public version omits exact request values and response bodies.

Impact

- Automated abuse of invoice-generation functionality
- Potential excessive invoice creation and administrative noise
- Possible resource consumption and workflow disruption
- Reduced reliability of transaction and audit records

Recommendation

- Implement rate limiting and anti-automation controls
- Use request uniqueness / idempotency controls where appropriate
- Validate transaction state before creating a new invoice
- Monitor abnormal replay and invoice-generation patterns

7. Security Controls Successfully Validated

The assessment also evaluated controls intended to resist common attack techniques and direct payment abuse. No exploitable issue was identified in the following areas at the time of testing:

Control Area	Result
Input Validation & Sanitization	PASS
Cross-Site Scripting (XSS) Protection	PASS
SQL Injection (SQLi) Protection	PASS
Payment Amount Validation	PASS
Payment Bypass Resistance	PASS

8. Conclusion

The assessment identified three findings across access control, API exposure, and abuse prevention. The highest-risk issue was the IDOR in invoice verification, which allowed unauthorized access to other customers' invoice information.

The assessment also demonstrated that several important controls were effective, including protections against XSS, SQL injection, direct payment bypass, and payment amount manipulation.

Remediation should prioritize object-level authorization for invoice access, restricting internal API documentation, and implementing robust anti-replay and rate-limiting controls.

9. Public Portfolio Notes

- Concrete invoice identifiers, customer records, and other potentially sensitive evidence from the original report have been redacted.
- The vulnerability mechanics and assessment outcomes are preserved for portfolio and professional-learning purposes.
- This publication assumes the engagement owner has authorized publication of the assessment content and target identification.